

信息安全管理规定

第一章 总则

第一条 为保障公司信息系统安全稳定运行，保护公司商业秘密和客户数据，依据《中华人民共和国网络安全法》《中华人民共和国数据安全法》《中华人民共和国个人信息保护法》及国家网络安全等级保护制度和相关法律法规制定本规定。

第二条 本规定适用于公司所有员工（含实习生）、外包服务人员和临时访客。

信息资产包括但不限于：计算机硬件和软件、网络设备、数据文件、电子文档、源代码、数据库和网络系统。

第三条 信息安全遵循以下基本原则：最小权限原则（仅授予完成工作所必需的最小权限）、职责分离原则（关键操作须双人复核）、纵深防御原则（多层防护，不依赖单一措施）、默认安全原则（新系统和设备的默认配置符合安全基线）。

第二章 账号与访问控制

第四条 每位员工拥有唯一系统账号，账号权限按岗位职责最小化分配。

新员工入职时，IT 部门根据 HR 提供的岗位信息创建账号并分配权限。

岗位变更时，原权限在 3 个工作日内收回，新权限在审批后 2 个工作日内开通。

离职员工的账号须在最后工作日 17:00 前禁用，所有权限须在 24 小时内全部收回。

第五条 密码策略：密码长度至少 12 位，须包含大写字母、小写字母、数字、特殊符号中至少三类；密码有效期为 90 天，到期前 7 天系统自动发送更换提醒。新旧密码的编辑距离不小于 5；连续 5 次输入错误密码将触发账号锁定 30 分钟。初始密码为随机生成，首次登录强制修改；严禁将密码记录在便签、文本文件或未加密的电子文档中。

第六条 特权账号（系统管理员、数据库管理员、域管理员等）实行更严格的管控：

须启用双因素认证（密码 + 动态令牌或生物识别）；密码每 30 天强制更换；

每次使用须填写操作工单并获 IT 负责人审批；操作过程须全程录屏并保存不少于 6 个月；

每月由 IT 安全团队审查特权账号使用日志。

第三章 网络安全

第七条 公司办公网络采用有线为主、无线为辅的架构。核心交换机和防火墙采用双机热备。

办公内网与访客网络物理隔离。访客网络仅提供互联网访问，带宽限制 10Mbps，无法访问任何敏感数据。

第八条 远程办公须通过公司 VPN 接入内网。VPN 采用 SSL 协议（AES-256 加密），会话最长 12 小时，空闲 30 分钟自动断开。VPN 账号每人限一个，严禁转借。

第九条 网络设备、安全设备和服务器须开启日志审计功能，日志保存不少于 6 个月。

安全事件相关日志保存不少于 3 年。日志须定期备份至离线存储介质，防止篡改和丢失。

第十条 IT 部门每季度进行一次漏洞扫描和风险评估，每半年委托外部专业机构进行一次渗透测试。扫描发现的漏洞按严重程度分级处理：高危漏洞 24 小时内修复，中危 7 日内，低危纳入下季度计划。

第四章 数据安全

第十一条 公司数据按敏感程度分为四级：

公开级（L1）：对外可公开的产品手册、新闻稿、招聘信息等，无须特别保护；

内部级（L2）：内部通知、会议纪要、培训材料、一般管理制度等，离开公司环境须脱敏或加密；

机密级（L3）：客户合同、财务数据、员工薪资、核心算法、源代码、商业计划等，传输和存储必须加密，访问须经部门负责人审批，禁止通过个人邮箱或即时通讯工具传输；
绝密级（L4）：公司战略并购计划、上市前财务数据、核心专利技术等，仅限 C - l e v e l 须使用专用加密设备，禁止离开公司物理环境。

第十二条 数据备份策略：核心业务数据每日增量备份、每周全量备份，备份数据异地存储，保留周期为最近 30 天的日备份 + 最近 12 个月的月备份 + 最近 3 年的年度备份。备份数据定期进行恢复演练，每季度至少一次，验证备份可用性和恢复流程。

第五章 终端安全

第十三条 所有公司电脑须安装公司指定的终端安全软件（EDR），保持病毒库和系统补丁为最新。

第十四条 电脑闲置 10 分钟自动锁屏。离开工位时须手动锁定。下班或长时间离开须关闭电脑。

第十五条 禁止在非公司设备上处理公司业务数据。禁止将公司数据上传至个人网盘或外部云服务。

第十六条 移动存储设备（U盘、移动硬盘等）接入公司电脑前须经 I T 部门登记和病毒扫描。机密级及以上数据严禁通过移动存储设备传输。

第六章 安全事件管理

第十七条 信息安全事件分级：一级（特别重大）——核心业务系统中断超过 2 小时或发生数据泄露；二级（重大）——非核心系统中断超过 4 小时或内部敏感数据异常外传；

三级（较大）——个别终端设备被恶意软件感染但未扩散；四级（一般）——钓鱼邮件未造成实际损失。

第十八条 任何员工发现信息安全事件须立即通过 I T 服务台（分机 8888）或安全事件邮箱报告。I T 安全团队须在 15 分钟内响应确认，1 小时内完成初步影响评估，一级事件 2 小时内启动应急预案并由 C T O 向 C E O 汇报。

第十九条 瞒报、迟报安全事件或擅自处理导致事态扩大的，视情节给予警告、通报批评、降职降薪、赔偿损失直至解除劳动合同等处分。

第七章 合规与培训

第二十条 全体员工每年须完成信息安全意识培训（不少于 4 学时），新员工入职 7 日内完成培训。

第二十一条 公司信息安全管理制度每年至少审视和修订一次，在发生重大安全事件后须在 30 日内完成制度修订并重新培训。